

Soluciones razonadas del cuaderno

E01-E04

E01. Path y query seleccionan operación/tamaño; Host selecciona vhost; cookie transporta sesión; JSON se deserializa y url puede llegar a un cliente HTTP. crop debe terminar en validación numérica. El error habitual es tratar todo como "parámetros HTTP" sin separar parsers.

E02. Source: request.args. Transformación: replace. El texto final llega a una shell por shell=True; subprocess.run es el sink. Quitar un separador no garantiza que el valor sea un único host ni elimina la gramática de shell. La alternativa es evitar shell, usar argv y validar el tipo de host.

E03. Hay un indicio de error dependiente de comilla, no SQLi confirmada. Compara entradas que ejerciten sintaxis válida/inválida, revisa mensaje/log del laboratorio y usa control con carácter especial no SQL. Mitigación: parametrización si el sink es SQL.

E04. HTTP, proxy o servicio propio son hipótesis. Una petición HTTP, una negociación del protocolo esperado y fingerprinting de banner/comportamiento las separan. "8080 = HTTP" es solo priorización.

E05-E10

E05. En el primer caso la entrada ocupa una expresión numérica; en el segundo está dentro de literal y necesita cerrar/reabrir o neutralizar sufijo. Pares condición verdadera/falsa deben respetar el motor y contexto. Se confirma por diferencia reproducible, no por extracción inmediata.

E06. A: la shell interpreta ; y puede ejecutar un segundo comando. B: todo es el último argumento de ping. Un marcador que produzca error de host literal en B y secuencia en A discrimina. Defensa: B con validación semántica.

E07. Desde /srv/reports/2026/julio/: ../../../../marker.txt. Normaliza julio -> 2026 -> reports -> srv, luego marker. El control inexistente separa lectura de respuesta cacheada. Defensa: ID indirecto y comprobación canónica.

E08. Usa URL del listener propio, registra origen, path y hora; control con puerto cerrado o nombre inexistente. Antes de loopback confirma que el servidor realiza la solicitud, qué esquemas admite y cómo resuelve/redirige. Defensa: política sobre destino efectivo.

E09. La matriz mantiene cuatro dimensiones y cambia una. Aceptación no implica acceso público; acceso no implica ejecución. Mitigación: nombre generado, fuera de webroot, bytes inspeccionados y handler sin ejecución.

E10. Está confirmada evaluación de expresiones compatible con una familia de sintaxis, no RCE ni motor exacto. Identifica motor por errores, documentación y comportamiento seguro; luego evalúa sandbox y exposición.

E11-E16

E11. Validación ocurre antes de URL decode, por eso compara una forma distinta de la consumida. La defensa decodifica una vez de forma definida, canonicaliza y comprueba confinamiento. Verifica con formas equivalentes que todas terminan rechazadas.

E12. No hay confirmación: la latencia base tiene un outlier similar. Alterna múltiples controles y pruebas, usa demora bastante mayor y analiza distribución/mediana. La mitigación depende del sink, no del canal temporal.

E13. Debe conocerse quién posee cada factura y conservar identidad/sesión. Confirma cuando B obtiene un objeto de A que debería estar prohibido y un control propio funciona. Cambiar IDs sin modelo de propiedad puede producir falso positivo.

E14. Confirma la regla exacta y ejecuta una operación inocua documentada que revele identidad, evitando impacto persistente. La capacidad procede de las funciones de find; otro binario tiene otra gramática. Mitigación: regla mínima sin escapes y binario específico.

E15. No basta. Debe existir un segmento candidato escribible, capacidad de colocar el ejecutable y oportunidad de reinicio/arranque. Comprueba ACL de cada ruta y control del servicio. Mitigación: comillas, ACL estrictas y cuenta mínima.

E16. El error indica desfase de reloj. Compara hora con DC y sincroniza dentro del laboratorio; después repite. Un error de permisos posterior es autorización, mientras que KRB_AP_ERR_SKEW impide validar autenticación.

E17-E20

E17. Secuencia: baseline autenticada, mismo objeto con segundo usuario, objeto propio del segundo, método alternativo, campo oculto modificado y sesión invalidada. Cada paso conserva todo lo demás. La evidencia es acceso/acción no autorizada, no una diferencia estética.

E18. Ejecuta identidad/sistema y después cada categoría. Avanza solo con regla sudo, binario SUID/capability relevante, cron con componente controlable, grupo peligroso o secreto reutilizable. La ausencia documentada descarta temporalmente, no el sistema completo.

E19. Primero resuelve el nombre mediante hosts/DNS, fingerprint HTTP y vhosts; en paralelo confirma SMB anónimo y dialecto, luego contenido web, backups, auth y reutilización solo con credenciales. SSH queda para credenciales válidas. Cada rama se cierra tras controles negativos y falta de nueva evidencia.

E20. Lectura LFI es confirmación. La contraseña en config es secreto; login SSH confirma reutilización. No tener sudo descarta solo ese vector. Cron es indicio hasta comprobar que root lo ejecuta y que un componente cargado, ruta, PATH o archivo es modificable. Un directorio escribible no vuelve escribible el script existente, aunque puede permitir reemplazo si permisos y operación lo permiten. Defensa: secretos separados, permisos mínimos y tareas con rutas/archivos protegidos.

Tipo test

1. B: dos condiciones reproducibles forman un oráculo.
2. C: el fragmento normalmente lo retiene el cliente.
3. B: sin shell es parte del argumento.
4. B: la arista exige condiciones y validación.
5. C: controla la semántica final de la ruta.